

Incident Investigation Report

NetSupport RAT Infection via Fake Browser Update (SmartApeSG)

— Host 10.11.26.183

Incident Information

Executive Summary

Alert Summary

Environment

Investigation Methodology

Investigation Findings

Indicators of Compromise (IOCs)

Timeline

Evidence Summary

MITRE ATT&CK Mapping

Impact Assessment

Recommendations

Conclusion

Appendix — Evidence Screenshots

← [Back to portfolio home](#)

Incident Investigation Report

NetSupport RAT Infection via Fake Browser Update (SmartApeSG) — Host 10.11.26.183

📄 [Download PDF version](#)

Note on evidence: This investigation is based on a public training exercise (packet capture and IDS alerts published by malware-traffic-analysis.net, 2024-11-26). The findings below are re-derived from that pcap and alert set. The appendix is intentionally left as a placeholder pending original Wireshark screenshots from the analyst’s own review of the capture, consistent with the evidence-backed format used in the other reports in this portfolio.

Incident Information

Field	Value
Incident ID	SOC-2024-11-26-001
Incident Type	NetSupport RAT Infection (SmartApeSG / fake browser update delivery)
Severity	High
Detection Source	IDS Signature Alerts (Suricata ET/ETPRO ruleset)
Analyst	Lakshmeesh R
Date Investigated	26-Nov-2024
Evidence Source	2024-11-26-traffic-analysis-exercise.pcap
Tool Used	Wireshark

Executive Summary

On 2024-11-26, IDS alerts flagged a Windows host on the internal network for a chain of increasingly severe activity: an initial lookup of a known fake-update (SmartApeSG/ZPHP) domain, followed by repeated HTTP POST traffic on TCP port 443 flagged as NetSupport RAT command-and-control (C2) check-in activity.

Correlating the alert set with the packet capture confirmed that host **10.11.26.183** was compromised after browsing a legitimate-but-compromised website that had been injected with a SmartApeSG redirect script. This redirect served a fake “browser update” file, which delivered the NetSupport Remote Access Trojan (RAT). The infected host then began beaconing to external C2 infrastructure at roughly one-minute intervals. The affected host’s MAC address, hostname, and Windows/AD user identity were confirmed by correlating LDAP and endpoint traffic in the capture.

Alert Summary

The IDS alert queue showed a cluster of alerts all tied to the same internal source IP, escalating in severity — from reconnaissance/policy-level alerts through to a confirmed trojan signature:

Alert (representative)	Significance
ET INFO Terse Request for .txt - Likely Hostile	Early anomalous request pattern
ET CURRENT_EVENTS ZPHP Domain in DNS Lookup / TLS SNI (modandcrackedapk.com)	Confirms contact with a known SmartApeSG (fake-update) domain
ET POLICY HTTP Request on Unusual Port Possibly Hostile	HTTP traffic seen on a non-standard port for the protocol
ET POLICY HTTP POST on unusual port 443 (POST)	Plaintext HTTP POST traffic sent over port 443, mimicking TLS traffic
ETPRO TROJAN NetSupport RAT CnC Activity	Confirmed NetSupport RAT command-and-control traffic
ETPRO TROJAN Malicious NetSupport Rat CnC Checkin	Confirmed periodic C2 check-in
ET INFO NetSupport Remote Admin Checkin / Response	NetSupport remote-admin protocol handshake observed
ET POLICY NetSupport GeoLocation Lookup Request	RAT performing a geolocation lookup on the victim host

Alerts of this type are grouped by destination IP/port; the same internal host (10.11.26.183) is the consistent source across the full alert cluster, with the NetSupport RAT alerts alone accounting for dozens of repeated check-ins over the observed window.

Environment

Item	Value
LAN Segment	10.11.26.0/24
Domain	nemotodes.health
AD Environment Name	NEMOTODES
Domain Controller	10.11.26.3 (NEMOTODES-DC)

LAN Gateway	10.11.26.1
LAN Broadcast Address	10.11.26.255

Investigation Methodology

The IDS alert queue was reviewed first to identify the affected host and the type of activity involved. The packet capture was then examined in Wireshark to confirm and expand on the alert findings:

- Alert triage — grouping by destination IP/port to identify the single affected internal host
 - HTTP filtering — isolating the repeated POST requests flagged as NetSupport RAT C2
 - LDAP filtering (`ldap.AttributeDescription == "givenName"`) — identifying the authenticated AD user's full name
 - Host/endpoint correlation — confirming IP, MAC, and hostname for the affected asset
-

Investigation Findings

1. Infected Windows Client

Field	Value
IP Address	10.11.26.183

Evidence: Every alert in the escalating cluster — from the initial ZPHP domain lookup through to the confirmed NetSupport RAT C2 checkins — shares the same internal source IP, **10.11.26.183**. This is corroborated by the underlying HTTP traffic in the capture, where repeated POST `http://194.180.191.64/fakeurl.htm` requests originate from this address.

2. MAC Address

Field	Value
MAC Address	d0:57:7b:ce:fc:8b

Evidence: The Ethernet frame headers for traffic sourced from 10.11.26.183 identify the hardware address as **d0:57:7b:ce:fc:8b**, consistent across the HTTP, DNS, and LDAP traffic reviewed for this host.

3. Hostname

Field	Value
Hostname	DESKTOP-B8TQK49

Evidence: Host/name-resolution traffic associated with 10.11.26.183 identifies the Windows hostname as **DESKTOP-B8TQK49**.

4. User Account

Field	Value
Username	oboomwald

Evidence: Authentication traffic between the host and the domain controller (10.11.26.3, NEMOTODES-DC) identifies the associated Windows/AD account as **oboomwald**.

5. User Full Name

Field	Value
Full Name	Oliver Q.. Boomwald

Evidence: Filtering the capture on `ldap.AttributeDescription == "givenName"` surfaces LDAP SASL GSS-API search requests containing the distinguished name `CN=Oliver Q.. Boomwald`, tying the AD account `oboomwald` to a full user identity.

6. Infection Vector — SmartApeSG (Fake Browser Update) Chain

The capture and associated alerts are consistent with a **SmartApeSG (also tracked as ZPHP)** infection chain — a long-running fake-browser-update campaign:

1. The victim browsed a compromised, otherwise-legitimate website (publicly identified in relation to this exercise as `classicgrand.com`) that had a malicious script injected into its page content.
2. The injected script silently contacted a SmartApeSG staging domain (`modandcrackedapk.com`), confirmed by both a DNS lookup alert and a TLS SNI alert for that domain.
3. The staging domain served a fake “your browser needs updating” prompt, delivering a malicious JavaScript file (publicly identified as `update.js`) disguised as a browser update.
4. Running the fake update ultimately delivered the **NetSupport RAT** payload to the host.

This chain matches the well-documented SmartApeSG / fake-update campaign pattern, in which a legitimate website is compromised to serve as a redirector toward attacker-controlled infrastructure, rather than being the final malware host itself.

7. Command-and-Control (C2) Traffic

Following infection, the host began issuing repeated HTTP POST requests to `http://194.180.191.64/fakeurl.htm` over **TCP port 443** — using plaintext HTTP rather than TLS on that port, which is itself an anomaly flagged by IDS policy alerts. These POSTs repeat at roughly one-minute intervals, consistent with a NetSupport RAT check-in beacon, and continue for an extended period in the capture.

Indicators of Compromise (IOCs)

IOC Type	Value
Internal Host	10.11.26.183
MAC Address	d0:57:7b:ce:fc:8b
Hostname	DESKTOP-B8TQK49
Username	oboomwald
Full Name	Oliver Q.. Boomwald
NetSupport RAT C2	194.180.191.64:443 — POST /fakeurl.htm
SmartApeSG (ZPHP) staging domain	modandcrackedapk.com

Likely compromised redirector site	classicgrand.com
Fake update payload	Update.js (browser-update lure)
Destination Port	TCP/443 (plaintext HTTP, not TLS)

Timeline

Time (UTC)	Event
~04:50	Estimated point of initial infection
04:53:47 - 04:54:57	LDAP traffic identifying the authenticated AD user (Oliver Q.. Boomwald)
05:07:49 - 05:08:49	First observed POST /fakeurl.htm to 194.180.191.64 — C2 beacon begins
05:09:49 - 05:30:52	Repeated POST /fakeurl.htm beacon at ~1-minute intervals, continuing through the observed capture window

Evidence Summary

Evidence	Protocol / Method
Host, MAC identification	HTTP / Ethernet header correlation
Hostname discovery	Name-resolution traffic
User authentication	AD/domain authentication traffic
Full user identity	LDAP (givenName attribute)
Infection vector	DNS / TLS SNI alerts for SmartApeSG domain
C2 confirmation	HTTP POST beaconing, IDS trojan signatures

MITRE ATT&CK Mapping

Technique	ID	Notes
Drive-by Compromise	T1189	Infection originated from browsing a compromised legitimate website
User Execution: Malicious File	T1204.002	Fake “browser update” file executed by the user
Ingress Tool Transfer	T1105	RAT payload delivered via the fake-update download chain
Masquerading	T1036	Malicious update disguised as a legitimate browser update prompt
Remote Access Software	T1219	NetSupport RAT used as remote access tooling
Non-Standard Port	T1571	Plaintext HTTP C2 traffic sent over TCP port 443 (typically reserved for TLS)
Application Layer Protocol: Web Protocols	T1071.001	C2 beaconing conducted over HTTP POST requests

Impact Assessment

Host **10.11.26.183 (DESKTOP-B8TQK49)**, used by domain account **oboomwald (Oliver Q.. Boomwald)**, was compromised via a fake browser-update lure and subsequently established recurring C2 communication with external infrastructure at **194.180.191.64**. NetSupport RAT provides an attacker with legitimate-looking remote administration capability — including remote desktop control, file transfer, and system reconnaissance (evidenced here by the observed GeoLocation lookup alert) — meaning this is a full remote-access compromise, not a passive infection.

Because LDAP/AD authentication traffic for this account was observed around the likely infection window, the account should be treated as potentially exposed alongside the endpoint. The use of port 443 for plaintext C2 traffic is a deliberate evasion choice intended to blend in with normal encrypted web traffic on network monitoring that inspects by port alone rather than by protocol content — worth noting when tuning detections.

This capture does not confirm whether the attacker took further action via the RAT (data access, lateral movement, additional payloads) — that requires endpoint forensics beyond what the pcap shows.

Recommendations

Immediate

- **Isolate the endpoint:** quarantine 10.11.26.183 via EDR network isolation or switch-port shutdown to cut off active C2 access while preserving forensic state.
- **Block the C2 indicator:** block 194.180.191.64 and the /fakeurl.htm URI pattern at the firewall/proxy.
- **Block the delivery chain:** block the SmartApeSG staging domain (modandcrackedapk.com) and monitor for related domains, since SmartApeSG infrastructure rotates frequently.
- **Contain the account:** reset credentials for oboomwald and review recent authentication activity for signs of misuse.
- **Forensic capture:** collect memory/disk images from the host to confirm RAT execution and check for any additional dropped tooling.

Long-Term

- Deploy web/DNS filtering against known fake-update / SmartApeSG-style domains, and subscribe to community threat feeds (e.g., malware campaign trackers) that publish newly observed staging domains, since this infrastructure changes often.
 - Tune IDS/EDR to flag plaintext HTTP traffic on port 443 specifically, since this is a low-noise but reliable indicator of C2 mimicking TLS.
 - Conduct user awareness training on fake “browser update” prompts served by compromised (not just malicious-looking) websites — the underlying site was otherwise legitimate.
 - Review other hosts on the LAN segment for the same C2 indicators, in case more than one machine was exposed to the same drive-by chain.
-

Conclusion

The investigation confirmed that Windows workstation **10.11.26.183 (DESKTOP-B8TQK49)**, MAC **d0:57:7b:ce:fc:8b**, used by domain account **oboomwald (Oliver Q.. Boomwald)**, was compromised via a SmartApeSG fake-browser-update chain that delivered the NetSupport RAT. The infected host subsequently beacons to **194.180.191.64:443** at regular intervals using plaintext HTTP disguised as TLS traffic. Correlating the IDS alert cluster with HTTP, DNS/TLS SNI, and LDAP evidence in the capture provided sufficient grounds to positively identify the affected asset, its user, and the full infection chain. The recommendations above should be actioned before the host is returned to service.

Appendix — Evidence Screenshots

Pending: this section will be completed with the analyst's own Wireshark screenshots from an independent review of 2024-11-26-traffic-analysis-exercise.pcap, following the same evidence format used in the other reports in this portfolio (filtered packet views for the C2 traffic, LDAP query, and host/endpoint identification).

Report prepared by Lakshmeesh R as part of a SOC investigation portfolio exercise. Investigation based on a public packet capture and alert set published by malware-traffic-analysis.net (2024-11-26 traffic analysis exercise).